

Security Policies

Microsoft Entra ID IAM & Zero Trust Lab

Project Title:

Microsoft Entra ID Identity and Access Management (IAM) with Zero Trust Security

1. Introduction

Identity and Access Management (IAM) is a critical component of modern cybersecurity. It ensures that only authorized users have access to organizational resources while protecting sensitive information from unauthorized access. This project implements core IAM concepts using Microsoft Entra ID and follows Zero Trust security principles.

The security policies defined in this document provide guidelines for managing user identities, authentication, authorization, and access control within the CyberSecurity Lab environment.

2. Purpose

The purpose of these security policies is to:

- Protect organizational resources.
- Ensure only authorized users can access systems.
- Apply the Principle of Least Privilege.
- Reduce insider threats.
- Improve compliance with cybersecurity best practices.
- Demonstrate enterprise IAM implementation using Microsoft Entra ID.

3. Scope

These policies apply to:

- All Microsoft Entra ID users
- Administrators
- Managers
- Contractors

- Security Groups
- Administrative Roles
- Identity Management Processes
- Cloud Resources

4. Identity and Access Management (IAM) Policy

The organization uses Microsoft Entra ID as its centralized identity provider. Every employee must have a unique digital identity. Access to systems and applications is granted according to business requirements and reviewed regularly.

Policy Requirements

- Every user must have a unique account.
- Shared accounts are prohibited.
- User identities must be verified before account creation.
- Access must be approved by the appropriate manager.
- Access rights must be removed immediately when no longer required.

5. Password Policy

Strong passwords are the first layer of defense against unauthorized access.

Password Requirements

- Minimum length: **12 characters**
- Must contain uppercase letters
- Must contain lowercase letters
- Must contain numbers
- Must contain special characters
- Passwords must not contain personal information.
- Password reuse is discouraged.
- Default passwords must be changed during first login.

Account Protection

- Users must never share passwords.

- Passwords must not be written on paper or stored in plain text.
- Passwords should be changed immediately if compromise is suspected.

6. Multi-Factor Authentication (MFA) Policy

Multi-Factor Authentication provides an additional layer of security beyond passwords.

Policy

- MFA should be enabled for all administrator accounts.
- MFA should be enabled for all users whenever licensing allows.
- Microsoft Authenticator is the preferred authentication method.
- SMS authentication should only be used as a backup.

Authentication Factors

- Password
- Microsoft Authenticator App
- Mobile Notification
- One-Time Password (OTP)

Project Note

The Microsoft Entra ID Free edition used in this lab does not support advanced MFA policies. MFA configuration is documented as part of the project and can be implemented using Microsoft Entra ID Premium (P1/P2).

7. Role-Based Access Control (RBAC) Policy

RBAC ensures users receive permissions based on their job responsibilities.

Assigned Roles

User	Administrative Role
Muhammad Awais	Global Administrator
Umer	Helpdesk Administrator
Asad	Security Administrator

User	Administrative Role
Ahmed	Default User
Bilal	Default User

Policy

- Administrative roles must only be assigned when necessary.
- Default users must not receive administrative privileges.
- Administrative roles should be reviewed regularly.
- Users should receive only the permissions required to perform their duties.

8. Least Privilege Policy

The Principle of Least Privilege (PoLP) ensures that users receive only the minimum permissions required for their role.

Policy

- Users receive standard access by default.
- Administrative permissions require approval.
- Excessive permissions must be removed immediately.
- Access should be reviewed after role changes.

Benefits

- Reduces attack surface.
- Limits insider threats.
- Prevents accidental misuse.
- Improves compliance.

9. Security Group Policy

Security groups simplify access management by assigning permissions to groups instead of individual users.

Configured Groups

- HR

- IT
- Managers
- Contractors

Policy

- Users must belong to only the groups required for their job.
- Group membership must be reviewed periodically.
- Department changes require immediate group updates.

10. User Account Management Policy

Account Creation

New user accounts require:

- HR request
- Manager approval
- Unique username
- Department assignment
- Security group assignment

Account Modification

User accounts must be updated when:

- Department changes
- Job role changes
- Promotion
- Name changes

Account Removal

Accounts must be removed immediately after employment termination.

11. Joiner-Mover-Leaver (JML) Policy

Joiner

- Create account

- Assign security group
- Assign default role
- Grant required access
- Register MFA (where available)

Mover

- Remove previous permissions
- Update security groups
- Assign new permissions
- Review administrative roles

Leaver

- Disable or remove account
- Remove security groups
- Remove administrative roles
- Revoke active sessions
- Remove licenses
- Document offboarding

12. Access Review Policy

Access reviews ensure that permissions remain appropriate over time.

Review Frequency

- Monthly for administrative accounts.
- Quarterly for standard users.

Review Items

- Group membership
- Assigned roles
- Unused accounts
- Inactive users

- Administrative permissions

Actions

- Keep access
- Modify access
- Remove access
- Delete inactive accounts

13. Conditional Access Policy

Conditional Access helps protect organizational resources by evaluating sign-in conditions.

Planned Policies

- Require MFA for administrators.
- Allow access only from trusted locations.
- Block legacy authentication.
- Restrict access from high-risk countries.
- Require compliant devices for administrative access.

Project Note

Conditional Access requires Microsoft Entra ID Premium P1 or P2 and is documented as a planned implementation because it is not available in the free edition used for this lab.

14. Privileged Access Management Policy

Administrative accounts should be carefully managed.

Policy

- Minimize the number of Global Administrators.
- Assign Helpdesk Administrator only to IT support staff.
- Assign Security Administrator only to security personnel.
- Review privileged accounts regularly.
- Remove unnecessary administrative roles.

15. Account Lockout and Offboarding Policy

When an employee leaves:

- HR notifies IT.
- User access is revoked immediately.
- Active sessions are revoked.
- Security groups are removed.
- Administrative roles are removed.
- Licenses are removed (if applicable).
- User account is disabled or deleted.

This process prevents unauthorized access by former employees.

16. Audit and Monitoring Policy

Microsoft Entra ID provides logging capabilities to monitor user activity.

The following logs should be reviewed regularly:

- Sign-in Logs
- Audit Logs
- Role Assignment Logs
- Administrative Activities
- Failed Authentication Attempts

Monitoring helps identify suspicious behavior and supports incident response activities.

17. Security Best Practices

The following best practices were followed in this project:

- Unique identity for every user.
- Security Groups for department-based access.
- Role-Based Access Control (RBAC).
- Principle of Least Privilege.
- Administrative roles assigned only where required.
- Identity lifecycle management using the Joiner-Mover-Leaver process.

- Regular access reviews.
- Immediate removal of unnecessary accounts.
- Strong password requirements.
- Documentation of all identity changes.

18. Conclusion

This project demonstrates how Microsoft Entra ID can be used to implement Identity and Access Management (IAM) and Zero Trust principles in a cloud environment. Security was improved through centralized identity management, department-based security groups, Role-Based Access Control (RBAC), least privilege enforcement, and a documented Joiner-Mover-Leaver (JML) workflow. Although advanced capabilities such as Conditional Access and enterprise MFA require Microsoft Entra ID Premium licensing, the implemented design follows industry best practices and provides a strong foundation for secure identity governance.